

Helios Cloud - Information Security Policy

1. Scope and Roles

This policy applies to every employee, contractor and service account at Helios Cloud, and to every system that stores or processes customer data. The Chief Information Security Officer owns the policy and is accountable for its enforcement across engineering, support and finance.

The policy is reviewed once a year, every March, by the security council. Changes approved at the March review take effect on the first day of the following quarter. Out-of-cycle changes may be made after a major incident, with sign-off from the CISO and the head of legal.

Each team nominates a security champion who attends the monthly champions forum and acts as the first point of contact for security questions within the team. Security champions receive additional training and are expected to review designs that touch customer data.

Exceptions to this policy must be requested in writing, approved by the CISO, and recorded in the exceptions register with an expiry date no more than 6 months away.

2. Access Control

Multi-factor authentication is required for every account that can reach production systems, the source code host, or the customer support console. Hardware security keys are required for administrators; other staff may use an authenticator app.

Passwords must be at least 14 characters long and must not appear in the breached-password list checked at login. Passwords are not rotated on a schedule, but must be changed immediately if compromise is suspected.

Access reviews are performed quarterly. Each manager confirms that every member of their team still needs each role they hold, and unconfirmed roles are removed automatically at the end of the review window.

When an employee leaves, all of their access must be revoked within 4 hours of their departure being recorded in the HR system. Shared credentials the person knew, such as break-glass accounts, are rotated within the same window.

3. Data Classification and Protection

Helios classifies data into four levels: Public, Internal, Confidential and Restricted. Customer content and credentials are always Restricted. Financial records and employee data are Confidential. The data owner assigns the level and records it in the data catalogue.

Restricted data must be encrypted at rest with AES-256 and in transit with TLS 1.2 or newer. Restricted data may not be copied to laptops, spreadsheets or chat tools under any circumstances.

Backups of production databases are taken every 6 hours and retained for 35 days. Backups are encrypted with keys held in a separate account, and a restore test is performed every quarter to confirm the backups are usable.

All company laptops use full-disk encryption and lock after 5 minutes of inactivity. Lost or stolen devices must be reported to IT the same day so they can be wiped remotely.

4. Incident Response

Security incidents are graded Sev1 to Sev4. For a Sev1 incident, the on-call security engineer must be paged and must acknowledge within 15 minutes. The incident commander opens a dedicated channel and a timeline document immediately.

If customer data is confirmed to have been exposed, affected customers are notified within 72 hours of confirmation. Regulators are notified where required by law, in coordination with the legal team.

Evidence such as logs, disk images and access records is preserved before any remediation that might destroy it. Systems are isolated rather than powered off, so that memory can still be captured.

A blameless postmortem is written within 5 business days of the incident being resolved. Action items from the postmortem are tracked in the security backlog and reviewed at the monthly security council meeting.